Entity-conditioned nulls for anomaly detection in authentication logs

Abstract

Anomaly detection on security telemetry is usually posed as outlier detection against a pooled population. We argue and then measure that this asks the wrong question: an account that is permanently unusual is not thereby suspicious, and one that has changed is suspicious whether or not it is unusual for the organisation. We condition each null on the entity that produced the event, so an authentication's reference set is that account's own history.

On the Los Alamos authentication corpus, where 549 labelled red-team events occur among 4.19 million scored events, a per-entity novelty test attains 15.7% precision (95% CI 9.0–26.0) at 10 alerts per analyst-day against a base rate of 1.31×10^{-4}, a lift of about 1,200. A structural census locates the mechanism: the properties per-entity tests express are enriched 139- and 184-fold among labelled events, while the property a population-rarity test expresses contains none of them.

Several negative results are of independent interest. Combining the arms' p-values never exceeds the best single component; alerting whenever any arm ranks an event highly is dominated at equal cost and superior at equal depth, at 3.7 times the volume; dividing the budget by demonstrated quality fails too, an exhaustive search over splits chosen with the labels in hand finding the optimum at the corner; and routing per entity, the one construction with headroom, collapses onto a single arm because history does not predict mechanism. Read as a zero-sum game against an adversary choosing the mechanism, that corner is a theorem rather than a measurement, and the conclusion usually drawn from it is also wrong: the best single arm guarantees nothing. Adding a seventh arm reaching one labelled event in 4.49 million costs the composite a quarter of its detections. Reweighting the selection by an account's history length is the one thing that pays, 35% at the deepest budget. Every result points the same way: what limits this framework is coverage, not allocation.

Keywords: anomaly detection; multiple testing; conditional inference; game theory; intrusion detection; decision theory.

---

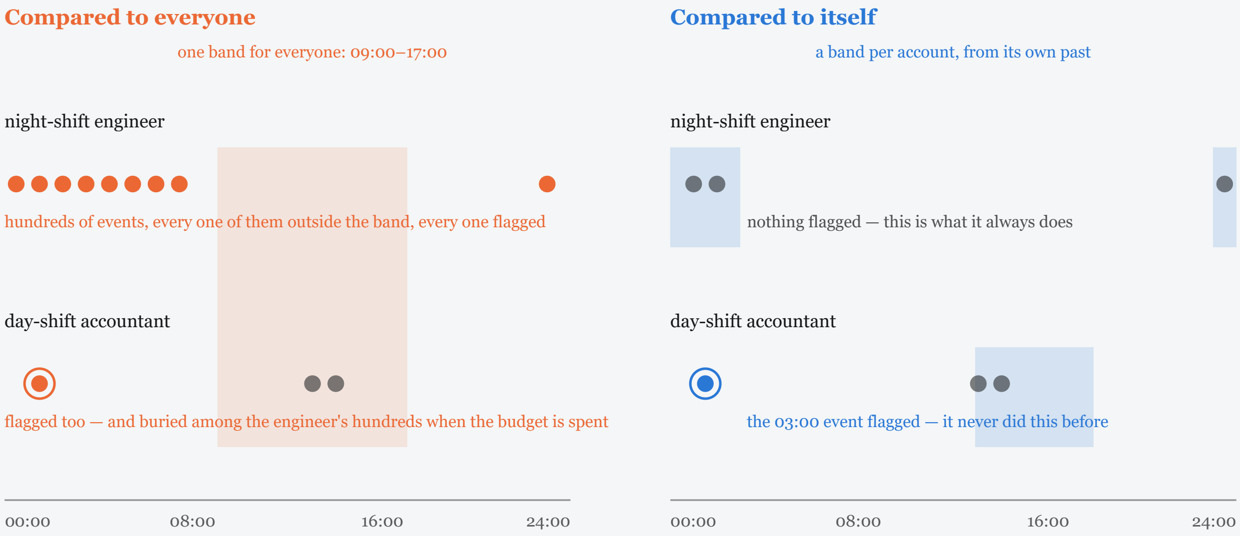
1. Introduction

An enterprise authentication log records who authenticated to what, from where, and how. Two features of the setting bound what any method can achieve.

Volume against rarity. 42.2 million events were scored over seven days and 549 are labelled, a base rate π of 1.30×10^{-5}. With α the per-event false-alarm rate, $P(\text{intrusion} \mid \text{alarm}) = \pi / (\pi + (1 - \pi)\cdot\alpha)$, so half a queue is real only at $\alpha \approx 1.3 \times 10^{-5}$ — about 78 false alerts a day. At $\alpha = 10^{-3}$, typical of published detectors, the same corpus yields some 6,000 false alerts against 78 real ones. This is Axelsson's base-rate argument [1] on our own data.

A fixed working day. Triage capacity is a staffing constant, not a tuning parameter, which is why every comparison here is at a matched number of alerts per analyst-day and never at a matched threshold: two methods thresholded alike may emit volumes differing by three orders of magnitude, and the comparison would then be between their volumes.

1.1 Why a population-scope null asks the wrong question



The reference moves with the account. Both panels hold the same two accounts and the same events. On the left one band serves everyone, and the failure is not that the accountant's 03:00 event goes unflagged — it is flagged. It is that the night-shift engineer is flagged on *every event it ever produces*, so the day's alert budget is spent on accounts that are behaving exactly as they always have, and the one event that matters is buried among them. On the right each account is judged against its own past: the engineer's night work is unremarkable, and the accountant's 03:00 event is the only thing left to look at. Nothing about the events changed, only what they were compared against.

A systems administrator who works nights and authenticates to database servers no one else touches is a persistent outlier and not an intruder; an account whose behaviour has just changed completely may still sit inside the population's bulk, because the values it moved onto are ordinary for other people. Both errors have one cause: "is this event unusual for this organisation" is not "has this account departed from its own behaviour". The two differ in the reference set against which an observation is judged exchangeable — all accounts, or one account's history. Conditioning on the entity is this paper's whole commitment.

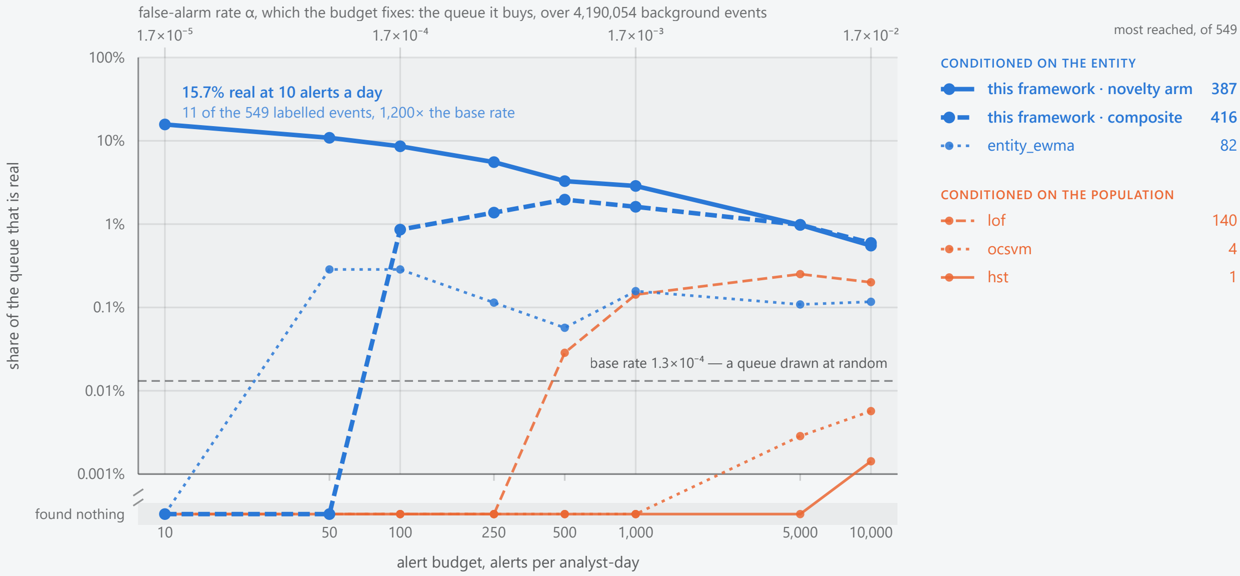
Seven questions are asked of each event, each returning a p-value under its own null or abstaining. Section 4 gives the estimators.

ARM	ASKS	SCOPE
`novelty`	has this account used this categorical value before?	per-entity
`noveltyrate`	is it producing first-ever values faster than it historically does?	per-entity
`pairing`	has this account combined these two values before?	per-entity
`timing`	is this hour unusual for this account?	per-entity
`volume`	is this much activity in this window unusual for this account?	per-entity
`drift`	has this account's rate shifted upward and stayed there?	per-entity
`marginal`	is this value rare across the whole population?	population

1.2 What this paper establishes

Share of the alert queue that is real, at each alert budget

4,190,603 events scored over 7 days · 549 labelled · a base rate of one in 7,633. Grouped by the scope of the null each method tests.



The comparison is a function of the budget, not a point. Every line is measured on the same slice: 4,190,603 scored events over 7 days, of which 549 are labelled, a base rate of one in 7,633. Each point is one method at one measured budget. A method that found nothing at a budget is drawn on the *found nothing* row below the axis break rather than omitted, so a flat line there reads as measured rather than as missing; the methods leave that row at six different budgets, which is the comparison this figure exists to make.

Colour is the scope of the null, not who wrote the method. Blue judges an event against the history of the account that produced it, orange against the pooled population (§1.2). `entity_ewma` is a comparator drawn in blue because it keeps a per-entity mean; this framework's arms are the heavier strokes in that family, and every method's scope is recorded in the curve file. A method's own α is lower than the budget's by the detections it found, at most 16% at 10 alerts a day and 0.6% at 10,000.

The figure draws the four comparators with the most detections over the budget range, so the choice does not flatter this framework; the other four reached too little to plot, and the table below lists all eight that were run. *Every reading here is an upper bound on this framework's disadvantage and a lower bound on its precision.* The corpus has no true negative class, so an unlabelled alert on genuine but unrecorded malicious activity counts as a false alarm (§12.5). The baselines read a fixed-length numeric vector per event and only `entity_ewma` holds per-entity state; they are not held to R2 or R4 (§12.4).

METHOD	JUDGED AGAINST	100 ALERTS / ANALYST-DAY			1,000 ALERTS / ANALYST-DAY		
		FOUND	PRECISION	RECALL	FOUND	PRECISION	RECALL
this framework, novelty arm	its own history	60	8.6%	11%	201	2.9%	37%
this framework, composite	its own history	6	0.86%	1.1%	113	1.6%	21%
entity_ewma	its own history	2	0.29%	0.36%	11	0.16%	2.0%
lof	the population	0	0	0	10	0.14%	1.8%
ocsvm	the population	0	0	0	0	0	0
hst	the population	0	0	0	0	0	0
rrcf	the population	0	0	0	0	0	0
eif	the population	0	0	0	0	0	0
iforest	the population	0	0	0	0	0	0
pca	the population	0	0	0	0	0	0

Every method that was run, at two budgets. A budget of *b* alerts per analyst-day buys a queue of $b \times 7$ alerts over the 7 days scored, whichever method spends it. *Found* is labelled events reached, *precision* the share of the queue that is real, and *recall* the share of the 549 labelled events reached.

Most of the comparators reach nothing at all: seven of the eight at 100 a day and six of the eight at 1,000 a day. A zero is measured, not missing — every method read the same events, which is why the figure above needs a row below its axis.

This framework's novelty arm reaches 11% of the campaign at 100 alerts a day and 37% at 1,000, against a base rate of 1.3×10^{-4} — a lift of 650× and 220×.

Recall counts what the red team wrote down, not what happened. The label file records an authorised exercise rather than annotating the log exhaustively, so unrecorded malicious activity counts against precision and is absent from the recall denominator (§12.5): both columns are lower bounds. Only `entity_ewma` holds per-entity state, and no comparator is held to R2 or R4 (§12.4).

The figure tracks each method across the operating range; the table fixes two budgets and includes every comparator the figure has no room to draw. Three results follow. Per-entity conditioning is worth a great deal, and the population arm is not merely weaker but *empty* on the real campaign, since no labelled event holds a population-rare value (Appendix B). Combining or dividing evidence never beats the best single arm, and under a known attack mix that is forced rather than measured. And the best single arm still guarantees nothing against an adversary who picks the mechanism — a coverage defect rather than an allocation one.

We do not claim state-of-the-art detection: 15.7% precision at the tightest budget is good against this base rate and not good enough to act on unattended. Nor that population-scope conditioning is useless — it retains one capability this framework lacks (§2.5) — nor generalisation beyond telemetry of this shape, nor to the full population: every figure is from an entity subset (Appendix A).

2. Results

All comparisons are at matched alerts per analyst-day over a seven-day window, so *B* means 7*B* alerts. Corpora, windows and sampling are in Appendix A; requirements R1–R6 are in Appendix C.

2.1 Detection on the real campaign

`lanl-r11-b1000-weighted-d7-14-005`, 549 labelled among 4,190,603 scored. Every proportion carries a 95% Wilson interval [7]; Appendix F states why those intervals are optimistic.

ARM	10/DAY	100/DAY	1000/DAY	PRECISION AT 10/DAY	RECALL AT 1000/DAY
`novelty`	**11**	**60**	**201**	**15.7% (9.0–26.0)**	36.6% (32.7–40.7)
`pairing`	4	59	127	5.7% (2.2–13.8)	23.1% (19.8–26.8)
`noveltyrate`	0	22	185	—	34.9% (31.0–39.1)
`timing`	1	2	7	1.4% (0.3–7.7)	1.3% (0.6–2.7)
`volume`	0	0	0	—	0.0% (0.0–0.7)
`marginal`	0	0	0	—	0.0% (0.0–0.7)
corrected minimum	4	47	162	5.7% (2.2–13.8)	29.5% (25.8–33.5)
composite	0	6	113	—	20.6% (17.4–24.2)

At the tightest budget `novelty` returns 11 true positives in 70 alerts, a lift of about 1,200; precision falls to 2.9% at 1000 alerts a day as recall rises to 36.6%, the ordinary consequence of taking a longer prefix of one ranking. `novelty` and `pairing` are **not distinguishable and should not be ranked** — at 100 alerts a day their recalls are 10.9% (8.6–13.8) and 10.7% (8.4–13.6), and a novel pairing is a novel value of a composite field. The `volume` and `marginal` zeros carry an upper bound rather than a point. The composite's zero at the two tighter budgets is not an artefact calibration removes: those figures are *with* conformal calibration, and without it the composite reaches 0 at 100 a day rather than 6.

On a corpus differing in background (`holdout-r7-fixed`, 262 labelled among 1,427,225) `novelty` gives 2, 8, 15 and 21 at 10, 25, 50 and 100 alerts a day and the composite 0 everywhere.

2.2 Detection by attack mechanism

Six planted kinds separate "cannot express this mechanism" from "cannot afford it": eight victims each, inside the scoring window, the planted value always the most population-common value the victim has never used, so population rarity is held out by construction (Appendix A). `lanl-inj-b1000-weighted-d7-14-005`.

The budget binds harder than the method. At 10 alerts a day no arm reaches any planted mechanism; at 100 exactly one is, account takeover, by the `marginal` (76) and the composite (26); at 1000 five of six are. For four of the six, "this framework does not detect it" is false at some budget and true at another, and only the budget changed.

At 1000 alerts a day, planted totals in the header. Every row spends the permitted 7,000 alerts except the equal-depth union at 31,505 (×4.5), and the baselines, at their own budgets on §2.5's sampled corpus.

METHOD	SPRAY /320	LATERAL /40	OFF-HRS /64	PRIV-ESC /24	LOW+SLOW /288	TAKEOVER /120	REAL /
`novelty`	80	15	0	0	0	30	**178**
`noveltyrate`	**117**	**26**	0	**4**	0	64	173
`pairing`	0	0	0	0	0	12	130
`timing`	0	0	**3**	0	0	11	7
`volume`	0	0	**1**	0	0	0	4
`drift`	0	0	0	0	**0**	0	1
`marginal`	0	0	0	0	0	**120/120**	0

METHOD	SPRAY /320	LATERAL /40	OFF-HRS /64	PRIV-ESC /24	LOW+SLOW /288	TAKEOVER /120	REAL /
composite	0	4	0	0	0	116	107
corrected minimum	40	10	0	0	0	28	156
union, all arms, equal cost	0	0	2	0	0	**120/120**	99
union, all arms, equal depth	**117**	**26**	**3**	**4**	0	**120/120**	**265**
`lof` — baseline	0	0	0	0	**12**	0	0
`ocsvm` —	0	0	0	0	0	33	0

The `drift` row is the sequential-change arm §3.3 introduces (`lanl-inj-b1000-drift-d7-14-006`). **It reaches 0 of 288 low-and-slow events**, the column it was built for, its one detection a real-campaign event; §3.3 says why. Adding it leaves every other row identical, and §2.4 measures its effect on the combinations. §2.3 adds a second arm built for the same column, with the same outcome.

No single method is best at more than one thing. The `marginal` takes every planted takeover and nothing else; `noveltyrate` takes spray, lateral movement and privilege escalation; `novelty` the real campaign. No row is deployable, which §2.3 formalises.

Low-and-slow is reached by no arm at any budget — 0 of 288, 0 of 8 victims — and the reason is measured rather than predicted. Repairing the null the mechanism was built to evade took `volume` 's sub-10^{-12} background from 13,618 events to 10,827 and its detections from nothing to five, without moving this column; its median p-value here is **0.72** against 0.31 to 0.49 elsewhere, so the response is not weak but *inverted*. §3.3 gives the mechanism, a property of the plant as much as of the arm.

The `marginal` 's 120 of 120 needs explaining, since population rarity is held out by construction. Its median p-value is 0.59 on spray and lateral movement, which substitute the destination computer, 0.17 on privilege escalation, which substitutes the authentication type, and 3.8×10^{-5} on takeover, which substitutes three at once: the pattern follows the **cardinality of the substituted field.** Destination takes 3,535 distinct values, so a common value the victim has not used is genuinely common; authentication and logon type take 14 and 10, three values accounting for 99.6% of resolved authentication types, so an account already using the common ones can only be given a tail value. **Holding population rarity out succeeds where the vocabulary is large and cannot where it is small** — a limitation of the planted corpus, stated because the alternative is to read the row as evidence for a mechanism the design excludes.

2.3 Allocation under an adversarial mix

Read the table above as a payoff matrix — rows arms, columns the mechanism an adversary chooses, entries P(detected | mechanism). Under a known mix p the expected detection of a randomised allocation w is $w^{\mathrm{T}}(\mathrm{A}p)$, *_linear in_ w***, and a linear form on a simplex attains its maximum at a vertex. So no prior-weighted mixture beats the best single arm; over 20,000 random priors, none does. The equilibria are the minimax solutions [18] by Dantzig's reduction [19]: `robust-inj-d7-14-002` , and `robust-inj-lof-d7-14-001` admitting a baseline.

The game's value is exactly zero. Every arm scores 0 on low-and-slow, so the saddle point is (any arm, low-and-slow) and a rational adversary wins outright. No reweighting of rows changes a column of zeros: the defect is coverage, not allocation, which is why §2.4's negative result cannot be repaired by a better rule.

What is well posed is to normalise each mechanism by the best rate any arm reaches and maximise the worst-case *fraction retained*, dropping the unreachable column:

OBJECTIVE	GUARANTEE	EXPECTED RATE	ALLOCATION
best single arm	**0**	**0.372**	any one arm — each is blind to some mechanism
competitive ratio	**0.421 of achievable**	0.217	`noveltyrate` 0.42, `timing` 0.42, `marginal` 0.16

The measured policy does not reach it, and the reason generalises. Routing on declared preconditions sends **117 of the 129 labelled entities to one arm**, every attacked account having history, so it reproduces that arm almost exactly — 0/21/381 against 0/21/384 — and loses at every budget to whichever arm is best (11/76/384). The disjointness that motivates routing is in *which events* each arm detects, and **history does not predict mechanism.**

Expected rate is under a prior weighted towards credential attacks and takeover. The optimum **equalises**, which makes one number mean something:

SPRAY	LATERAL	OFF-HRS	PRIV-ESC	TAKEOVER	REAL
0.421	0.421	0.421	0.421	0.421	0.426

Five of six sit exactly at the guarantee; the real campaign is not binding and low-and-slow is excluded, not covered.

Coverage is purchasable, and not by reweighting. Labelled events found on the planted corpus at 1000 alerts a day, against the worst mechanism's retained fraction:

RULE	FOUND	ALERTS	WORST-CASE RETAINED
best single arm (`noveltyrate`)	**384**	7,000	0
randomised, even over the two best arms	344	7,000	0
corrected minimum	234	7,000	0
composite	227	7,000	0
union, all arms, equal cost	221	7,000	0
randomised, competitive-ratio mixture	189	7,000	**0.421**
union, all arms, equal depth	535	31,505 (×4.5)	**1.000**
per-entity routing, oracle floor–ceiling	*448–535*	*7,000*	—
per-entity routing, stated policy	381	7,000	—

No rule in §2.4 guarantees anything at all. Two allocations do, and the table prices both: retain 42.1% of the achievable on every reachable mechanism at the same budget for 42% of expected detection, or buy the guarantee at 4.5 times the alerts.

Two further readings. **Randomising is not dividing, and only dividing had been tested**: §2.4 measures unions and splits, giving every arm a fraction of its depth, where a mixed strategy runs one arm at full depth by lottery. And **routing is not a global allocation** — choosing per entity, it can send an established account to a per-entity null and a cold one to the population null and collect both. Its floor is what any per-entity policy matches, its ceiling the union at full depth; both are oracles charging no alert cost.

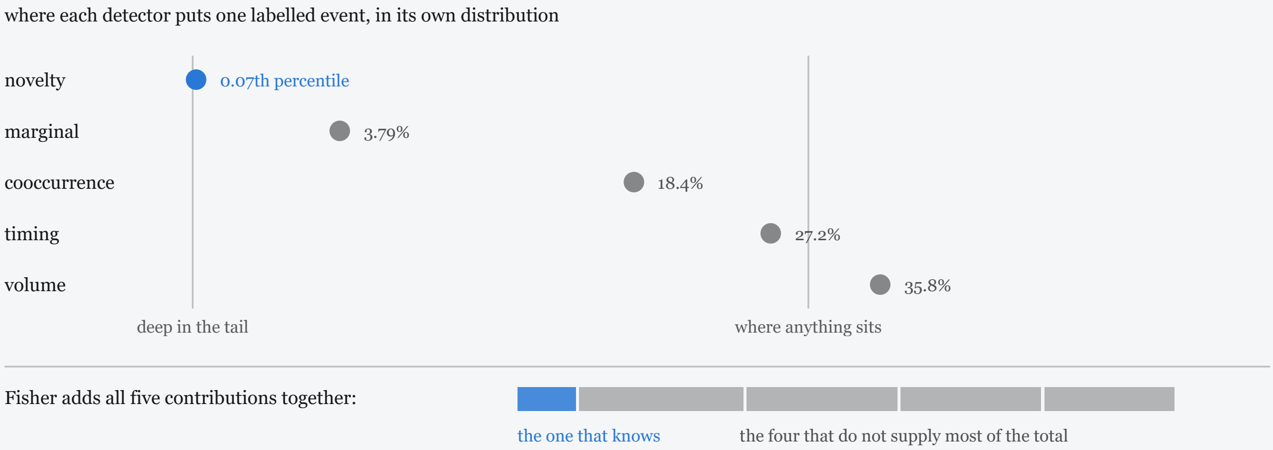
Admitting a low-and-slow-capable arm prices the excluded column. With `lof` from §2.5 admitted every mechanism is reachable and the guarantee over all seven falls to **0.296** at **59%** of expected detection: covering the hole is expensive, and the two figures bracket the choice rather than settling it. `lof` comes from a hundredfold easier sampled problem, so it is an existence proof rather than a matched comparison, which is why the framework's own arms carry the primary result.

Two further strategy sets were measured and **change none of this**. §3.3's sequential-change arm and an inter-arrival arm built for this column — the span of k consecutive arrivals against a Gamma(κ, θ) renewal null fitted per entity — both leave low-and-slow unreachable, the guarantee at 0.421, the price at 42% and the maximin value at zero, and both take weight zero in the optimum (`robust-inj-drift-d7-14-001` , `robust-inj-burst-d7-14-001`). An arm reaching nothing no other arm reaches cannot move an equilibrium, the same linearity from the other side.

That result says why the column is hard, not merely that it is. The arm abstains on none of the 288 plants, scoring them at a minimum p of 0.31 against 1.1×10^{-8} on spray: capable here, and finding the plant unremarkable. All eight victims are heavily clustered — κ from 0.004 to 0.107 against a mean gap of 425 s — so twelve arrivals ninety seconds apart are *slower* than their own short gaps, and a proximity test finds only events closer together than the account's habit.

Two properties of the equilibrium are reported in Appendix G: what happens once the adversary is charged for the mechanism it picks, which removes low-and-slow from its reply and concentrates the allocation on `timing` ; and where the next unit of detector work is worth spending, which is in none of the columns §2.1 and §2.2 compare arms on. **Marginal improvement to `novelty` against `noveltyrate` , which is what §2.1's headline turns on, has a shadow price of exactly zero.**

2.4 Why combination and allocation do not help



At 100 alerts a day, of 262 labelled events: novelty alone 21 · most-extreme-of-five 20 · **the five-detector sum 0**

More evidence is not better when most of it is not evidence. Fisher's method asks whether the evidence is jointly unusual, which is the right question only when every detector is informative. Here one is: it places the median labelled event at the 0.07th percentile of its own distribution, more extreme than 99.93% of all traffic. The other four place it where any event would sit. The sum is dominated by the four, so a composite built from a component that finds 21 labelled events finds none — and no cleverer combiner recovers it, because the remedy is not a better average but not averaging in detectors that know nothing.

RULE	10/DAY	100/DAY	1000/DAY	ALERTS AT 1000/DAY
best single arm	**11**	**60**	**201**	7,000
union, per-entity arms, equal cost	2	27	106	7,000
union, all arms, equal cost	2	21	96	7,000
union, per-entity arms, equal depth	11	74	278	25,930 (×3.7)
union, all arms, equal depth	11	74	278	32,134 (×4.5)

At equal cost the union is strictly dominated at every budget, with non-overlapping intervals at the widest: 17.5% (14.5–20.9) against 36.6% (32.7–40.7). At equal depth it finds what no single arm does, 278 against 201, for 3.7 times the alerts.

The two p-value rules fail for different reasons. **Fisher's sum averages an informative test with uninformative ones**: labelled events sit at the 0.07th percentile of `novelty`'s own distribution and between the 18th and 36th of every other arm's, so summing −2 ln P over six tests dilutes one signal with five non-signals — Fisher's method is powerful against diffuse alternatives and the minimum against sparse ones, and this alternative is sparse. **The corrected minimum compares p-values across tests sharing no scale**: `novelty` supplies 5,979 of the 7,000 retained alerts and `volume` never supplies the minimum. Removing the scale mismatch made the `marginal`'s signal reachable and the equal-cost result got *worse*, so it was not the binding defect.

Adding an arm tests the dilution directly. The seventh arm of §2.2 reaches one labelled event in 4.49 million and abstains on two thirds of them, so it is close to a controlled injection of noise. Adding it at 1000 alerts a day, every single arm's count unchanged, takes the corrected minimum from 234 detections to **134** on the planted corpus and 162 to **59** on the real campaign, and the composite 227 to **171** and 113 to **60** (`lanl-inj-b1000-drift-d7-14-006`, `lanl-r11-b1000-drift-d7-14-006`). The loss is larger where the signal is sparsest.

Dividing by demonstrated quality fails too, and the failure is bounded. A per-alert likelihood ratio fitted per arm on burn-in (Appendix D) loses at every budget on both corpora:

RULE	`R11` 100/DAY	`R11` 1000/DAY	`INJ` 100/DAY	`INJ` 1000/DAY
best single arm	**60**	**201**	**76**	384
weighted, burn-in weights	56	164	56	231
best two-arm split, oracle	60	**201**	77	**395**

Refitting the weights on the evaluation labels — an oracle — separates the arms properly, 0.19, 0.22 and 0.23 for the per-entity arms against 0.71 for `timing` and 1.0 for `volume`, and the rule still loses. **The construction fails, not the fit.** An oracular search over two-arm splits finds the real campaign's optimum at the corner at both budgets, and diverting 5% costs 13 detections at 1000 a day, so the derivative is negative *at* the corner. §2.3 reaches the same bound without an oracle: the objective is linear, so its optimum is a vertex whatever the weights are fitted on.

The mechanism is that **the arms are substitutes rather than complements** — `novelty` also finds 74.6% of `noveltyrate`'s detections and 78.7% of `pairing`'s, so splitting halves each arm's depth and what survives largely coincides. Where the arms genuinely are complements the same search finds headroom, the control this argument needs: the `marginal`'s 76 detections at 100 alerts a day overlap the per-entity arms' by **zero**, and the best split gives it 75 alerts and `novelty` 25, for 77 against 76; at 1000, 150 and 850 for 395 against 384. Both gains are inside sampling error. Overlap decides it.

2.5 Population-scope baselines

Eight reference implementations spanning four inductive biases were run on the same events, labels and budgets: isolation forest [11], extended isolation forest [12], half-space trees [13], local outlier factor [14], one-class SVM [15] and PCA reconstruction error, from scikit-learn [16], plus an uncalibrated per-entity EWMA z-score.

On the matched comparison all six population models detect **0 at every budget**, which Appendix B's census explains. On the planted corpus the exception is the interesting one — one-class SVM reaches 33 of 120 takeovers and **local outlier factor 12 of 288 low-and-slow events, the one mechanism no arm of this framework reaches at any budget**. A burst is what `volume`'s over-dispersion tolerates and a density estimate does not: a capability this framework lacks, and why the two scopes are complementary rather than ordered. Both come from an easier problem in the way that dominates — a 1-in-100 sample of 45,071 rows, raising the labelled share to 3.1%.

2.6 Reweighting the selection by history length

For a first-ever value equation (4) reduces to about 1/n, so history length sets the p-value's scale while being no part of the question asked. Weights learned per history-length stratum on burn-in and frozen at the boundary [21][22][23] give, on the matched injected corpus:

ARM	10/DAY	100/DAY	1000/DAY	P × N, MEDIAN	STRATA FLOORED
`novelty`	11 → 11	60 → **63**	303 → **410**	3.3 → 16.2	0
`timing`	2 → 2	9 → **15**	21 → **34**	2,840 → 1.6×10^8	4
`volume`	0 → 0	1 → 1	5 → **7**	1,790 → 8.1×10^7	4
`marginal`	0 → **7**	76 → **30**	120 → **60**	1,440 → 6.1×10^7	2
`pairing`	4 → 4	59 → 59	142 → 142	45 → 45	—
`noveltyrate`	0 → 0	21 → 21	384 → 384	319 → 319	—

It works where it was aimed. `novelty` gains 107 labelled events at 1000 a day, 35% more, its fitted weight falling about twentyfold from the shortest history stratum to the longest — the direction $1/n$ requires.

The rest are not covariate corrections, and the last column says so. A stratum whose estimated null proportion clamps to one earns weight zero, and a top-B selection cannot drop those events, so they are floored and rank last: with four of five strata floored, `timing` and `volume` alert only on their shortest histories, and $p \times n$ moving four orders of magnitude reports that rather than a corrected scale. `pairing` and `noveltyrate` clamped everywhere, so their weights fell back to uniform. The composite is unweighted, having no score before the boundary to fit on.

---

3. Discussion

3.1 What the evidence supports

Conditioning each null on the entity is supported on this campaign, and specifically: the properties per-entity tests express are enriched 139- and 184-fold among labelled events, and the property a population-rarity test expresses contains none of them. That direction is what the evidence establishes, and it is narrower than "per-entity beats population conditioning" — on planted attacks the population test detects a mechanism no entity-scope test here reaches, and a population density estimate reaches a second.

Combining evidence is not supported: five rules, none exceeding its best component at equal cost at any budget. Allocation is not supported either, and §2.3 states why independently of this corpus: the objective is linear in the allocation, so its optimum is a single arm. What §2.3 adds is that the corollary usually drawn — deploy the best arm — is also wrong. Both point at the same place: **coverage, not allocation**.

Storey's estimator [24] reads miscalibration as signal, which bounds where covariate weighting is usable. The estimated null proportion measures departure from uniformity — signal where the null is sound, misspecification where it is not — which is the difference between `novelty`'s smooth table and `timing`'s four floored strata. Calibrate first, weight second.

3.2 Principal limitations

Appendix F carries the full set with its measurement; two dominate.

The `novelty` p-value is confounded with history length. For a first-ever value the estimate reduces to $a/(n + a(K+1)) \approx 1/n$. Across 32 planted victims spanning 263 to 20,666 events of history, the product of the p-value and the history length has median 1.15 and lies in [0.50, 7.22]: among novel events the ranking is close to sorting accounts by event count. Clearing the arm's realised cut needs of the order of 10^5 events of history and the busiest planted victim had 20,666, so **no attack on an ordinary account could win a slot whatever it did**. Reserving unseen mass by Good–Turing instead *lost* detections here, large histories carrying many singletons so the correction judges a first-ever value unremarkable for exactly the accounts the working estimator ranks highest. **That is a property of this corpus, not the correction**: on a synthetic corpus where 16,800 innocent daily novelties fill the budget, the switch takes `novelty` from **0 of 864 plants to all 864** at 1000 a day.

A sustained intrusion enlarges its own reference set. State is committed after scoring, so an event is judged against a history excluding it — but the next event of the same campaign is not, so over days the reference distribution drifts toward the attacker. It is an untested alternative explanation for two null results, the low-and-slow zero in particular, and cannot be separated from the stated mechanism without a run that freezes per-entity state across the campaign window.

3.3 What is repaired, and what a deployable version needs

Two arms of §2.2 were **not evidence about per-entity conditioning in either direction**, and both are now repaired. `timing`'s zeros were a ceiling rather than blindness: its tail mass was floored by its own 512-point grid at or above its realised alert cut, so it could not alert whatever it observed, and a finer grid would not help because a tail mass over density levels saturates. Standardising the event's ln U against the mean and spread this entity's own events received removes the floor, which is what §2.2's row records.

`volume` was misspecified in the opposite direction — 27,464 background events on `r11` below 10^{-12} where a calibrated null predicts 4.2×10^{-6} — and the cause was a gate rather than the model. The width of its null is measured from the entity's own completed windows, and that measurement was gated on a *discounted* weight, which saturates at $1/(1-\delta)$: an entity whose active windows are more than about 55 hours apart could never measure its own dispersion however long it was watched, and fell back to the un-widened null for exactly the entities it had no evidence about. On synthetic benign accounts a burst every four days put 31.6% of its own events below 10^{-12}, reaching 10^{-45}. Gating on undiscounted observations instead gives §2.2's repair.

A discounted weight answers how recent, not how many, and gating a sample size on it makes the gate unsatisfiable rather than slow. The same defect had the same shape elsewhere: `timing`'s standardisation required a discounted weight of 20, which a once-daily account saturating at 10.6 could never reach.

The repair does not reach low-and-slow, for two reasons that are not defects in the arm. The plant is a seventeen-minute burst, three times, and `volume`'s null is deliberately over-dispersed so an ordinary burst does not alert: removing its false alarms and detecting this pull in opposite directions. And the burst sits in the victim's *usual* hour, where the expected count is highest, while off-hours — the one mechanism `volume` reaches — sits twelve hours away where it is lowest, so that detection arrives through the activity fraction ρ, as timing rather than volume.

That needs a statistic it does not contain rather than a refit: an over-dispersed marginal test of one period cannot see a drift small in every period, because the evidence is in the sequence. Page's one-sided cumulative sum [17] accumulates it, growing linearly in the number of periods while the spread of its null grows as the square root. On synthetic streams fitted on identical stationary history **it separates a sustained +30% shift from matched stationary variation by 237× where the volume predictive separates it by 1.2×** — and two details earn that, both cases of a null that must not follow what it measures: the running period is charged the whole reference value while contributing only the events seen so far, and the null over S is undiscounted while the baseline rate is, which alone takes the separation from 2× to 237×.

On the corpus it does not work, and the reason is instructive. The arm reaches 0 of 288 planted low-and-slow events, median p 0.77 there against 0.62 on the real campaign, so its response is *inverted* rather than weak. Three things account for it and only the first is a defect in the statistic. The planted mechanism is three bursts of about seventeen minutes rather than a sustained elevation, so a cumulative sum over daily periods is the wrong instrument. **Both instruments this paper predicted would be right have since been measured and neither moves the column** — repairing `volume`'s tail, and §2.3's sub-hourly test. The plant is also shorter than the arm's warm-up: its null needs eight closed periods and a seven-day burn-in supplies seven. And the inversion has a mechanism, §3.2's second limitation by another route: the null over S is undiscounted so a campaign cannot inflate it, but the baseline rate is discounted and the planted events raise it, which raises the reference value and floors the sum.

One gap separates what is measured from what can be run: **a fixed budget is a batch construction.** Selecting the top *B* of a day requires the whole day, and an operator at 14:00 does not know what arrives by 23:59 — as for a per-day Benjamini–Hochberg step-up. §4.4's objective, Appendix D's score and alpha-investing [26][27] are all built to the streaming constraint, and running the last closes that gap while leaving the other open: over 4,494,396 tests at $q = 0.1$ its level reaches 1.1×10^{-12} and `novelty` never clears it, **0 rejections**, while on the composite it rejects 79,286 at a realised rate of **0.995**. Valid error control at this scale demands a threshold the signal does not reach on the one arm worth calibrating, and concedes everything on the arm that is not. What is missing is a calibrated per-alert probability, not a streaming rule.

One direction is closed rather than open. Learning the allocation online is the adversarial bandit setting [20], whose regret $\sqrt{2TK \ln K}$ looks survivable — 89 detection-units against 10,481 over a year at $K = 6$. But the bound assumes the reward is observed each round and it is not: labels are the object of the search, and separating §2.1's top two arms at 80% power needs about 41,000 labelled events per arm against 549. **A learner cannot converge to an equilibrium it lacks the samples to see**, so the allocation must be stated.

---

4. Method

4.1 The entity-conditioned null

Write an event as field–value pairs with an entity *e* and a time *t*. For each field the framework maintains a per-entity summary of *e*'s history, decayed exponentially in event time with a seven-day half-life, and asks H_0: *this observation is exchangeable with e's own decayed history for this field.* Nothing is specific to authentication — what makes a question available is the inferred kind of the field, not its name.

ARM	PREDICTIVE
`novelty`	Dirichlet–multinomial over decayed counts; a first-ever value receives the reserved mass $a/(n + a(K+1))$
`noveltyrate`	Beta-binomial over *e*'s own rate of producing first-ever values, on an hourly window
`pairing`	`novelty`'s estimator on a synthetic composite field, so the question stays per-entity
`timing`	von Mises KDE on the 24-hour circle, as a truncated Fourier series; bandwidth 1.5 h
`volume`	Gamma–Poisson over *e*'s completed periods, deliberately over-dispersed
`drift`	Page's one-sided cumulative sum over per-period counts, standardised against *e*'s own sums
`marginal`	the same Dirichlet form over decayed *population* counts

Two properties are load-bearing. `novelty`'s reserved mass is $\approx 1/n$, so **the p-value for a first-ever value is set by the length of the account's history rather than by how surprising the value is** (§3.2); `noveltyrate` exists because of that and asks a scale-free question instead. And `volume`'s over-dispersion makes it tolerant of ordinary bursts and blind to sustained small increases, which §2.2 confirms and §3.3 addresses.

A population-scope relational arm was measured and retired. It asks whether two values co-occur as often as the population's degree structure predicts, and on this corpus 18.4% of scored events fell below 10^{-12} while it detected nothing at any budget — an account that always uses NTLM and its own workstation has a near-zero observed co-occurrence weight against an expectation in the hundreds, so its null collapses on every event for the account being consistently itself. That is §1.1's disavowed population-norm question by another route; `pairing` asks the per-entity form instead. The population form is retained for the ablation, not the default.

An arm may score several fields; it takes the most extreme, with a Šidák correction where it combines fields internally.

Ordering is the leakage control: every arm scores against pre-event state, the combination is computed, and only then are observations committed, so a first-ever value is still novel when scored. The rule cuts the other way too, which is §3.2's second limitation.

4.2 Field inference and abstention

R2 requires that no component be told a field's type. A registry observes values as they arrive and settles each field into one of five kinds — categorical, boolean, discrete, continuous, identifier — after which arms iterate the registry rather than a list of names.

The identifier kind carries the weight. A field whose values are almost all distinct — a session GUID, a request id — is unbounded by construction: every value is first-ever, so a novelty test on it fires on every event and consumes the whole budget, so arms decline such fields: without that the headline arm is a random-number generator with a large p-value. A field merely *open* must still be scored, and a space-saving sketch bounds its state — 12,522 values against 238,621 — but only if it reports what it evicted: the Good–Turing reserve reads the singleton rate, which lives in the tail, and withholding it took novelty to **0**.

R3 makes abstention an outcome: it reduces the number of tests combined rather than contributing a p-value of one. At this base rate that matters, because a neutral value entered into a combination over six tests is not neutral but evidence of ordinariness, and in Fisher's sum five of them bury one informative test.

4.3 Combination and calibration

RULE	STATISTIC	WHAT IT ASKS
composite	Fisher's $X^2 = -2\,\Sigma \ln P\_j$ on $\chi^2(2J)$, with Brown's correction [3, 4]	is the evidence *jointly* unusual?
corrected minimum	$P = 1 - (1 - \min\_j P\_j)$^J, Šidák [5]	did *any* arm find *e* out of character?
union, equal cost	best rank in any arm, truncated to the shared budget	the same, with the p-value scale removed
union, equal depth	best rank in any arm, every arm keeping its own top *B*	the same, paying for the depth

Brown's correction requires a positive variance estimate for X^2 and does not get one here: with six arms the burn-in covariance implies $\mathrm{Var}[X^2] = -27.5$, which no joint distribution can produce. The correction is then not applied and the combination degrades to plain Fisher, so **every composite figure in this paper is Fisher's statistic without Brown's correction**; Appendix F reads the negative estimate.

A fused rank is not calibrated against any of these nulls and carries no tail-probability interpretation; it reports a selection, and each alert still carries the p-value of the arm that raised it. Rank collisions are structural — every arm has a rank 1 — and break on event identity rather than on log P.

Conformal calibration [6] is applied optionally and orthogonally, replacing each arm's model tail with that value's rank in its own burn-in distribution, which is super-uniform whether or not the model is correct. Being monotone it cannot change any arm's own ordering, so per-arm figures are identical with and without it; what it changes is which arm supplies the minimum. It floors every p-value at $1/(n+1)$.

4.4 The decision problem

R6 states that alert volume follows from a stated exchange rate rather than a quota, because quotas are pathological: a system tuned to emit 100 alerts a day emits 100 on a quiet day too, all benign. If nothing happened, the right number of alerts is zero. We score an alerting configuration by $U = v \cdot TP - c \cdot FP$, with v what catching one incident is worth and c what one wasted investigation costs. Only v/c is identifiable from counts, so an operator supplies one number, and a queue is worth reading exactly when $TP/FP > c/v$.

Maximising a ratio does not work, and the failure is structural. TP/FP is precision under the monotone transform $P/(1-P)$, and precision's maximiser is the smallest queue containing a true positive; forbidding TP = 0 moves that corner from "alert on nothing" to "alert on one thing". **Any objective that is a function of precision alone is scale-free, and a scale-free quantity cannot say how many rows to show.** The same disposes of accuracy, balanced accuracy, F1 and Youden's J — each an unstated exchange rate wearing a metric's clothes; alerting on nothing scores 99.9987% accuracy.

A budget is therefore a **ceiling rather than a quota**: within it the queue is truncated where marginal alerts stop paying. Appendix E measures what that costs and buys at v/c = 10, stated in advance.

References

1. Axelsson, S. *The base-rate fallacy and its implications for the difficulty of intrusion detection*. ACM Conference on Computer and Communications Security, 1999.
2. Kent, A. D. *Comprehensive, Multi-Source Cyber-Security Events Data Set*. Los Alamos National Laboratory, 2015. CC0 1.0.
3. Fisher, R. A. *Statistical Methods for Research Workers*. Oliver and Boyd, 1932.
4. Brown, M. B. *A method for combining non-independent, one-sided tests of significance*. Biometrics 31(4), 1975.
5. Šidák, Z. *Rectangular confidence regions for the means of multivariate normal distributions*. Journal of the American Statistical Association 62(318), 1967.
6. Vovk, V., Gammerman, A. and Shafer, G. *Algorithmic Learning in a Random World*. Springer, 2005.
7. Wilson, E. B. *Probable inference, the law of succession, and statistical inference*. Journal of the American Statistical Association 22(158), 1927.
8. Benjamini, Y. and Hochberg, Y. *Controlling the false discovery rate: a practical and powerful approach to multiple testing*. Journal of the Royal Statistical Society B 57(1), 1995.
9. Benjamini, Y. and Yekutieli, D. *The control of the false discovery rate in multiple testing under dependency*. Annals of Statistics 29(4), 2001.
10. Chernoff, H. *On the distribution of the likelihood ratio*. Annals of Mathematical Statistics 25(3), 1954.
11. Liu, F. T., Ting, K. M. and Zhou, Z.-H. *Isolation Forest*. IEEE International Conference on Data Mining, 2008.
12. Hariri, S., Carrasco Kind, M. and Brunner, R. J. *Extended Isolation Forest*. IEEE Transactions on Knowledge and Data Engineering 33(4), 2021.
13. Tan, S. C., Ting, K. M. and Liu, T. F. *Fast anomaly detection for streaming data*. International Joint Conference on Artificial Intelligence, 2011.
14. Breunig, M. M., Kriegel, H.-P., Ng, R. T. and Sander, J. *LOF: identifying density-based local outliers*. ACM SIGMOD, 2000.
15. Schölkopf, B., Platt, J. C., Shawe-Taylor, J., Smola, A. J. and Williamson, R. C. *Estimating the support of a high-dimensional distribution*. Neural Computation 13(7), 2001.
16. Pedregosa, F. et al. *Scikit-learn: machine learning in Python*. Journal of Machine Learning Research 12, 2011.
17. Page, E. S. *Continuous inspection schemes*. Biometrika 41(1/2), 1954.
18. von Neumann, J. *Zur Theorie der Gesellschaftsspiele*. Mathematische Annalen 100(1), 1928.
19. Dantzig, G. B. *A proof of the equivalence of the programming problem and the game problem*. In Koopmans, T. C. (ed.), *Activity Analysis of Production and Allocation,* Wiley, 1951.
20. Auer, P., Cesa-Bianchi, N., Freund, Y. and Schapire, R. E. *The nonstochastic multiarmed bandit problem*. SIAM Journal on Computing 32(1), 2002.
21. Genovese, C. R., Roeder, K. and Wasserman, L. *False discovery control with p-value weighting*. Biometrika 93(3), 2006.
22. Ignatiadis, N. and Huber, W. *Covariate powered cross-weighted multiple testing*. Journal of the Royal Statistical Society Series B 83(4), 2021.
23. Hu, J. X., Zhao, H. and Zhou, H. H. *False discovery rate control with groups*. Journal of the American Statistical Association 105(491), 2010.
24. Storey, J. D. *A direct approach to false discovery rates*. Journal of the Royal Statistical Society Series B 64(3), 2002.

25. Donoho, D. and Jin, J. *Higher criticism for detecting sparse heterogeneous mixtures*. Annals of Statistics 32(3), 2004.
26. Foster, D. P. and Stine, R. A. *Alpha-investing: a procedure for sequential control of expected false discoveries*. Journal of the Royal Statistical Society Series B 70(2), 2008.
27. Ramdas, A., Yang, F., Wainwright, M. J. and Jordan, M. I. *Online control of the false discovery rate with decaying memory*. Advances in Neural Information Processing Systems 30, 2017.

Appendix A. Data and evaluation design

The Los Alamos comprehensive cyber-security events data set [2], CC0: 1.05 billion authentication events over 58 days from 12,425 users and 17,684 computers, with a labelled red-team exercise embedded. A record carries nine fields; an uninterpretable value is written `?`, distinct from absence throughout.

The unit of analysis is a human account; machine accounts, `SYSTEM` and `ANONYMOUS LOGON` are excluded at no cost, all 104 accounts the red team touched being human. The label file carries 749 rows, 715 distinct, naming those 104, and is concentrated: 93.6% of rows share one source computer, and two of seven scored days carry 482 of the 700 post-boundary labels. It records what the red team did and is not an exhaustive annotation, so activity it missed counts as a false positive and **every precision figure here is a lower bound**. Failed authentications appear only for accounts that succeeded somewhere in the data set, so the failure population is conditioned on eventual success — a property of the archive rather than of a live stream, and one the arms score.

Windows. The first seven days are burn-in: events are scored, so state warms under the code path scoring uses, but nothing is emitted. Two quantities are fitted there and frozen at the boundary — a between-arm covariance and a conformal calibration (§4.3) — and neither is ever updated by an event it is later used to score. The window was fixed before any end-to-end measurement and costs the 49 labelled events inside it. Scoring runs over days 7–13.

Sampling. Three of four designs are entity samples, a fixed alerts-per-day budget being a far harder target on 42.2 million events than on 4.2 million. Every labelled account is retained in every sample, which inflates the labelled share, so each base rate is stated.

DESIGN	SELECTOR	SCORED EVENTS	LABELLED	BASE RATE
full	none	42,218,530	549	1.30×10^{-5}
`r11`	1 entity in 16, residue 11	4,190,603	549	1.31×10^{-4}
`inj`	1 entity in 16, residue 7, plus planted attacks	4,494,396	1,405	3.13×10^{-4}
`holdout-r7`	days 7–8 of the residue-7 corpus	1,427,225	262	1.84×10^{-4}

Labelled accounts being exempt from sampling, the residue-7 and residue-11 corpora share their labelled events and differ only in background and window: a result reproduced across them checks sensitivity to background, not independent replication.

Planted mechanisms. Six named kinds, eight victims each, inside the scoring window. Victims are disjoint from every account the real labels name, so the account alone determines which ground truth an event belongs to.

MECHANISM	CONSTRUCTION	EVENTS	PREMISE ISOLATED
credential spray	many never-used destinations within ten minutes	320	categorical novelty and its rate
lateral chain	connected hops, each sourced from the previous destination	40	novel *pairings* of real values

MECHANISM	CONSTRUCTION	EVENTS	PREMISE ISOLATED
off-hours	only familiar values, twelve hours from the account's window	64	the circular timing null alone
privilege escalation	an authentication type absent from the account's history	24	novelty on a low-cardinality field
low-and-slow	familiar values only, twelve extra events a day for three days	288	the volume null alone
account takeover	destination, authentication type, logon type and hour all change	120	an upper bound: everything at once

The decision that matters statistically is the choice of planted value: **the most population-common value the victim has never used**. Sampling the vocabulary uniformly instead plants population-rare values, and a population-rarity test then detects the plant for the wrong reason. Value choice is deterministic, so every victim of a kind receives the same planted values: the events of one kind are not independent draws and the effective sample size is nearer eight than the event count. Sensitivity against planted labels says whether a test responds to a mechanism, not whether it detects an intrusion, so the two ground truths are never summed.

Appendix B. The structural census

Before any arm, what property of a labelled event could a method exploit? We census five structural properties of an event relative to the history it was scored against, defined by facts about the event and the history and never by which arm produced the smallest p-value — a partition defined by our own arms would flatter the framework by construction. On `r11`, 4,190,603 scored events of which 549 are labelled:

PROPERTY	LABELLED	SHARE	BACKGROUND	SHARE	LIFT
novel pairing for this entity	362	65.9%	19,841	0.473%	**139**
novel value for this entity	215	39.2%	8,913	0.213%	**184**
volume burst for this entity	199	36.2%	1,143,820	27.3%	1.3
outside this entity's hours	181	33.0%	1,576,171	37.6%	0.9
population-rare value	0	0.0%	4,835	0.115%	**0.0**

The properties are not mutually exclusive and 92 labelled events exhibit none of them.

Population rarity is not merely weaker, it is **empty**: not one labelled event holds a population-rare value while 4,835 background events do, so a population-rarity test here is a test of something the campaign does not exhibit. That is the strongest form this paper's central claim takes, and it is a statement about this campaign — §2.2 shows the property behaving differently on planted attacks. Volume bursts and out-of-hours activity are not enriched at all, which bounds what work on those two arms could recover; §3.3 gives the other half of each explanation.

Appendix C. Requirements

	REQUIREMENT
R1	A verdict is a function of the event and of persisted state only, so scoring is reproducible from the record and independent of batching.
R2	No component requires advance knowledge of a field's type, cardinality or value set. One field must be declared the entity, and one the timestamp; nothing else.
R3	Abstention is an outcome. A component with no basis for an opinion says so, and does not contribute a neutral value.
R4	Scoring is deterministic: no wall clock, no randomness, and a canonical total order before every floating-point reduction.
R5	A verdict carries the evidence needed to reconstruct it.

	REQUIREMENT
R6	Alert volume follows from a stated exchange rate between a missed intrusion and a wasted investigation, not from a quota.

Appendix D. The likelihood-ratio allocation rule

Two quantities are fitted per arm on burn-in and frozen: a null over that arm's own log p-value, and the single parameter a of a Beta(a, 1) density over the null quantiles its labelled burn-in events received. An alert at quantile q from an arm of weight a scores $s = \ln a + (a - 1) \ln q$, the log-likelihood ratio of its being labelled against its being background. Alerts from arms sharing no p-value scale are comparable on s, so the budget goes to the highest scores and no share parameter is chosen.

A weight is retained only where twice its log-likelihood ratio against $a = 1$ exceeds 2.706, the 5% one-sided point at the boundary of the range [10]; without that guard fifty uniform draws fit $a \approx 1 \pm 0.14$ and noise alone buys a large share of the queue. Labelled events an arm evaluated without surfacing enter right-censored.

The fit separates the arms as intended — on `r11` the three per-entity arms are informative at a = 0.376, 0.414 and 0.491, while `timing`, `volume` and the `marginal` surface none of the 49 labelled burn-in events and are fitted uninformative. §2.4 reports that it is not enough. One property survives and is why the implementation retains it: every quantity s reads is a property of the single alert or of state frozen before the window, so the same arithmetic that ranks a batch thresholds a stream.

Appendix E. Truncation at a stated exchange rate

At v/c = 10 as stated in §4.4, on the corrected-minimum arm:

BUDGET	PERMITTED	TP	OPTIMAL	TP	PRECISION	SUPPRESSED	TP FORGONE
10/day	70	4	**30**	4	5.7% → **13.3%**	40 (57%)	**0**
100/day	700	47	**221**	47	6.7% → **21.3%**	479 (68%)	**0**
1000/day	7,000	162	**315**	74	2.3% → **23.5%**	6,685 (95%)	88

At the two tighter budgets the truncation is free. At 1000 it becomes a decision: the objective discards 6,685 alerts and 88 true positives, because at this rate those 88 do not pay for 6,685 wasted investigations. For the composite the optimum is to emit nothing at any budget — an objective declining to deploy a detector is a usable answer. It uses the labels, so this measures headroom rather than being a deployable rule.

Reporting at a nominal false discovery rate is not available here. Benjamini–Hochberg [8] per day on the composite at q = 0.05 yields 5,352 discoveries of which 113 are labelled, a realised FDR of 0.979 (0.975–0.982), five of seven days saturated; Benjamini–Yekutieli [9] gives 0.978 at q = 0.001. The defect is in the composite, not the procedures — §10.1 calibrates each detector's **marginal** and a step-up reads a function of several of them.

Brown corrects only the variance, since c·f = 2J identically, and over 4.19 million events the empirical effective degrees of freedom are 4.4–11.3 against a nominal 24–34: twelve to seventeen arms carry about six, and the correction credits them with thirty.

Calibrating the composite against its own burn-in distribution repairs the level. As a within-run control — identical events, inputs, covariance and split — the uncalibrated form rejects 732 events at q = 0.001 and moves by 0.023 across the grid; the calibrated one rejects nothing until q = 0.1, at 0/5/**111** true positives against 0/6/**113**. Where it does reject the realised rate is still 0.978: this repairs the control, not the evidence.

Appendix F. Threats to validity

§3.2 carries the two dominant. The rest:

THREAT	MEASUREMENT	DIRECTION
effective sample far below nominal	549 events on 104 accounts; 93.6% of label rows share one computer; 8 victims per planted mechanism	**every interval is optimistic**
quantities chosen on the outcome	the best arm, the union's break-even rates, §2.4's split search, Appendix E's optimum; 7 arms × 5 rules × 3 budgets × 2 corpora, maxima reported	favours the framework; stated as oracle bounds, outer loop unadjusted
not measured at full population	the one full run scored 42,218,530 events with 4 of 7 arms, its composite detecting nothing	a budget is far easier on a subset
Brown's correction unavailable	$\mathrm{Var}[X^2] = -27.5$, which no joint distribution produces, so the estimate measures the marginals' misspecification rather than the arms' dependence	**every composite figure is plain Fisher**; a corrected composite awaits calibrated marginals
entity-day aggregation flatters recall	four ways over 4,944 entity-days at 100 alerts a day: Fisher 74 of 172 labelled entity-days, Higher Criticism [25] 69, corrected minimum 67, count-normalised 43 — against 3 for the event ranking	**not** the confound: the normalised forms bracket Fisher's, and the unit change is what pays
§2.3 inherits its matrix's limits	event-level rates where the effective sample is nearer eight victims; `lof` from a 100× easier sample	`lof` is an existence proof, not a matched row; the adversary knows the allocation but not the realised draw

Appendix G. Adversary cost, and where work is worth spending

A value-zero equilibrium assumes an uncovered mechanism is free to mount, and low-and-slow is slow by construction. Charging λ times a stated per-mechanism cost, low-and-slow at twelve times spray, on the strategy set with `lof` admitted so the priced mechanism is one some arm reaches:

Λ	VALUE	ALLOCATION	ADVERSARY'S REPLY
0	0.019	`lof` 0.47, `timing` 0.42, `noveltyrate` 0.12	low+slow 0.47, off-hrs 0.42, priv-esc 0.12
0.005	0.043	`timing` 0.80, `noveltyrate` 0.20	off-hrs 0.78, priv-esc 0.22
0.02	0.061	`timing` 0.87, `noveltyrate` 0.13	off-hrs 0.78, priv-esc 0.22
0.05	0.092	`timing` 0.89, `noveltyrate` 0.11	off-hrs 0.89, spray 0.11

Any appreciable cost removes low-and-slow from the reply. The costs and λ are stated, never fitted: a cost fitted to the labels the allocation is scored against would make the equilibrium a restatement of the corpus. The concept is properly Stackelberg, the defender committing first, which coincides with §2.3's for zero-sum games and not once mechanism costs differ.

Shadow prices. Every cell whose improvement by 0.10 raises the guarantee lies in low-and-slow, off-hours or privilege escalation — the mechanisms in the adversary's reply. The largest are `timing` on low-and-slow (+0.017), `lof` on off-hours (+0.014) and `noveltyrate` on low-and-slow (+0.012), and not one lies in the four columns §2.1 and §2.2 compare arms on.

Data and code availability

Every number here is read from a machine-generated result file committed alongside the source, each carrying its run identifier, corpus checksums, row counts, seeds and parameters. No figure is a plot of data: each is a diagram of a mechanism, so no figure can disagree with a result. §2.3's equilibria are solved from the recorded per-mechanism matrix by `cmd/robust` and need no corpus, so they reproduce from this repository alone. The corpus is third-party and is not redistributed.

Generated by `cmd/thesis` from `docs/PAPER.md`, which stays canonical for the prose: this page is never edited directly, so the two cannot disagree. Every quantitative claim traces to a recorded run in `results/`. Diagrams are hand-authored inline SVG with no external resources, and their two carrying colours are validated for contrast and colour-vision separation against both the light and dark surfaces.